

CODTECH IT SOLUTIONS

Big Data Internship — Task 4

Big Data Security & Compliance Framework

A Comprehensive Framework for GDPR and HIPAA Compliance in Big Data Systems

Prepared By	DEEPAK YADAV
Internship Domain	Big Data
Organization	CODTECH IT Solutions
Date	25 th MAY 2026
Compliance Standards	GDPR (EU 2016/679) · HIPAA (45 CFR Parts 160/164) · ISO 27001

1. Executive Summary

This report presents a comprehensive Big Data Security and Compliance Framework designed to ensure that large-scale data processing systems meet the requirements of major regulatory standards including GDPR, HIPAA, and ISO 27001. As organizations handle exponentially growing volumes of sensitive data through platforms like Apache Hadoop, Apache Spark, and cloud-based data lakes, the need for robust security controls, data governance policies, and compliance mechanisms has become mission-critical.

This framework addresses data classification, access control, encryption, audit logging, incident response, and compliance monitoring — providing both architectural guidelines and practical implementation patterns for Big Data environments.

2. Regulatory Compliance Overview

2.1 GDPR — General Data Protection Regulation

The EU General Data Protection Regulation (GDPR) sets strict standards for the collection, storage, and processing of personal data of EU citizens. Key GDPR principles applicable to Big Data systems include:

- Lawfulness, Fairness, and Transparency — Data must be processed with a valid legal basis.
- Purpose Limitation — Data collected for one purpose cannot be repurposed without consent.

- Data Minimization — Only necessary data should be collected and retained.
- Accuracy — Personal data must be kept accurate and up to date.
- Storage Limitation — Data should not be retained longer than necessary.
- Integrity and Confidentiality — Appropriate technical and organizational security measures are required.
- Accountability — Organizations must demonstrate compliance through documentation.

2.2 HIPAA — Health Insurance Portability and Accountability Act

HIPAA governs the protection of Protected Health Information (PHI) in the United States. Big Data healthcare systems must comply with HIPAA's Security Rule which includes:

- Administrative Safeguards — Policies, procedures, and workforce training.
- Physical Safeguards — Physical access controls to hardware and data centers.
- Technical Safeguards — Access controls, audit controls, integrity controls, and transmission security.
- Breach Notification Rule — Mandatory notification within 60 days of a PHI breach.

3. Data Classification Framework

All data processed in the Big Data system must be classified according to sensitivity level before any processing, storage, or transmission occurs.

Classification	Description	Examples	Controls Required
PUBLIC	Non-sensitive, publicly available data	Aggregated stats, reports	Basic access logging
INTERNAL	For internal use only	Employee data, transactions	Role-based access, encryption
CONFIDENTIAL	Sensitive business or personal data	PII, financial records	AES-256 encryption, MFA
RESTRICTED	Highly sensitive regulated data	PHI, payment card data	Full HIPAA/GDPR controls

4. Security Architecture

4.1 Access Control — Role-Based Access (RBAC)

All access to Big Data systems must follow the Principle of Least Privilege. The following RBAC roles are defined:

- Data Engineer — Read/write access to raw and processed data zones; no production access.
- Data Analyst — Read-only access to anonymized/aggregated datasets.
- Data Admin — Full access with mandatory audit logging; MFA required.
- Compliance Officer — Read access to audit logs and compliance dashboards only.

- External API User — Scoped OAuth 2.0 tokens with rate limiting and field-level masking.

4.2 Encryption Standards

- Data at Rest: AES-256-GCM encryption for all HDFS blocks, S3 buckets, and database volumes.
- Data in Transit: TLS 1.3 for all network communication between Spark workers and data stores.
- Key Management: AWS KMS / HashiCorp Vault for centralized key rotation (minimum 90-day rotation).
- Column-level Encryption: Applied to all PII fields (SSN, email, phone, medical record IDs).
- Tokenization: Payment card data and sensitive IDs replaced with non-sensitive tokens.

4.3 Data Anonymization & Masking

Before datasets are made available for analysis, the following anonymization techniques must be applied:

- K-Anonymity ($k \geq 5$) — Ensures any individual cannot be distinguished from at least $k-1$ others.
- L-Diversity — Sensitive attributes in each equivalence class have at least l distinct values.
- Differential Privacy — Statistical noise added to query results ($\epsilon = 0.1$ for high-sensitivity data).
- Data Masking — Production data masked before copying to development/test environments.

5. Audit Logging & Monitoring

A comprehensive audit trail must be maintained for all data access and processing operations. The following events must be logged:

- All read/write access to RESTRICTED and CONFIDENTIAL datasets.
- Failed authentication attempts and privilege escalation events.
- Schema changes, data deletion, and bulk export operations.
- ETL pipeline executions with input/output record counts and user context.
- API calls including request parameters, response codes, and caller identity.

Logs must be stored in an immutable, tamper-proof store (e.g., AWS CloudTrail + S3 with Object Lock) and retained for a minimum of 3 years (HIPAA) or as required by applicable law.

5.1 Real-Time Monitoring

- SIEM Integration: Apache Kafka + ELK Stack (Elasticsearch, Logstash, Kibana) for real-time log aggregation.
- Anomaly Detection: ML-based models to detect unusual data access patterns.
- Alerting: PagerDuty/Slack alerts for compliance threshold violations within 15 minutes.

6. Data Retention & Right to Erasure

Data retention schedules must be defined and enforced for all data categories:

Data Type	Retention Period	Deletion Method	Regulation
Customer PII	Duration of contract + 2 years	Cryptographic erasure	GDPR Art. 17
Health Records (PHI)	6 years minimum	DoD 5220.22-M wipe	HIPAA §164.530
Transaction Logs	7 years	Secure deletion + audit	Financial regulations
Audit Logs	3 years (HIPAA) / 6 years (GDPR)	Archived then deleted	Both

7. Incident Response Plan

In the event of a data breach or security incident, the following response procedure must be executed:

- Step 1 — Detection (0–1 hour): SIEM alerts trigger incident ticket creation. Security team notified immediately.
- Step 2 — Containment (1–4 hours): Isolate affected systems. Revoke compromised credentials. Block suspicious IPs.
- Step 3 — Assessment (4–8 hours): Determine data categories and volume affected. Identify root cause.
- Step 4 — Notification (within 72 hours): GDPR requires notification to supervisory authority within 72 hours. HIPAA requires notification within 60 days.
- Step 5 — Remediation: Patch vulnerability. Rotate all encryption keys. Update access controls.
- Step 6 — Post-Incident Review (within 2 weeks): Full incident report, lessons learned, and updated controls.

8. Compliance Checklist

Control	GDPR	HIPAA
Data Classification Framework implemented	☒	☒
AES-256 encryption at rest	☒	☒
TLS 1.3 encryption in transit	☒	☒
Role-Based Access Control (RBAC)	☒	☒
Multi-Factor Authentication (MFA)	☒	☒

Audit logging (immutable)	☒	☒
Data Retention Policy enforced	☒	☒
Right to Erasure mechanism	☒	—
Data Processing Agreements (DPAs)	☒	—
Business Associate Agreements (BAAs)	—	☒
Breach Notification Procedure (72hr/60day)	☒	☒
Anonymization / K-Anonymity applied	☒	☒
Annual Compliance Audit	☒	☒

9. Conclusion

This Big Data Security and Compliance Framework provides a structured approach to protecting sensitive data across all stages of the Big Data pipeline — from ingestion and processing to storage and visualization. By implementing the controls, policies, and monitoring mechanisms outlined in this report, the organization can achieve and maintain compliance with GDPR, HIPAA, and ISO 27001 standards.

Regular security audits, penetration testing, and compliance reviews must be conducted at least annually, with continuous automated monitoring in place. The framework should be treated as a living document, updated as regulations evolve and new technologies are adopted.

During this internship, I explored real-world Big Data compliance challenges and implemented controls aligned with industry standards.

Prepared for CODTECH Big Data Internship — Task 4 Deliverable